

Atelier 5 : traitement du risque



OBJECTIF : Définir une stratégie de traitement du risque et identifier les risques résiduels

ÉLÉMENTS EN ENTRÉE :

- Socle de sécurité (**atelier 1**)
- Mesures de sécurité portant sur l'écosystème (**atelier 3**)
- Scénarios stratégiques (**atelier 3**)
- Scénarios opérationnels (**atelier 4**)



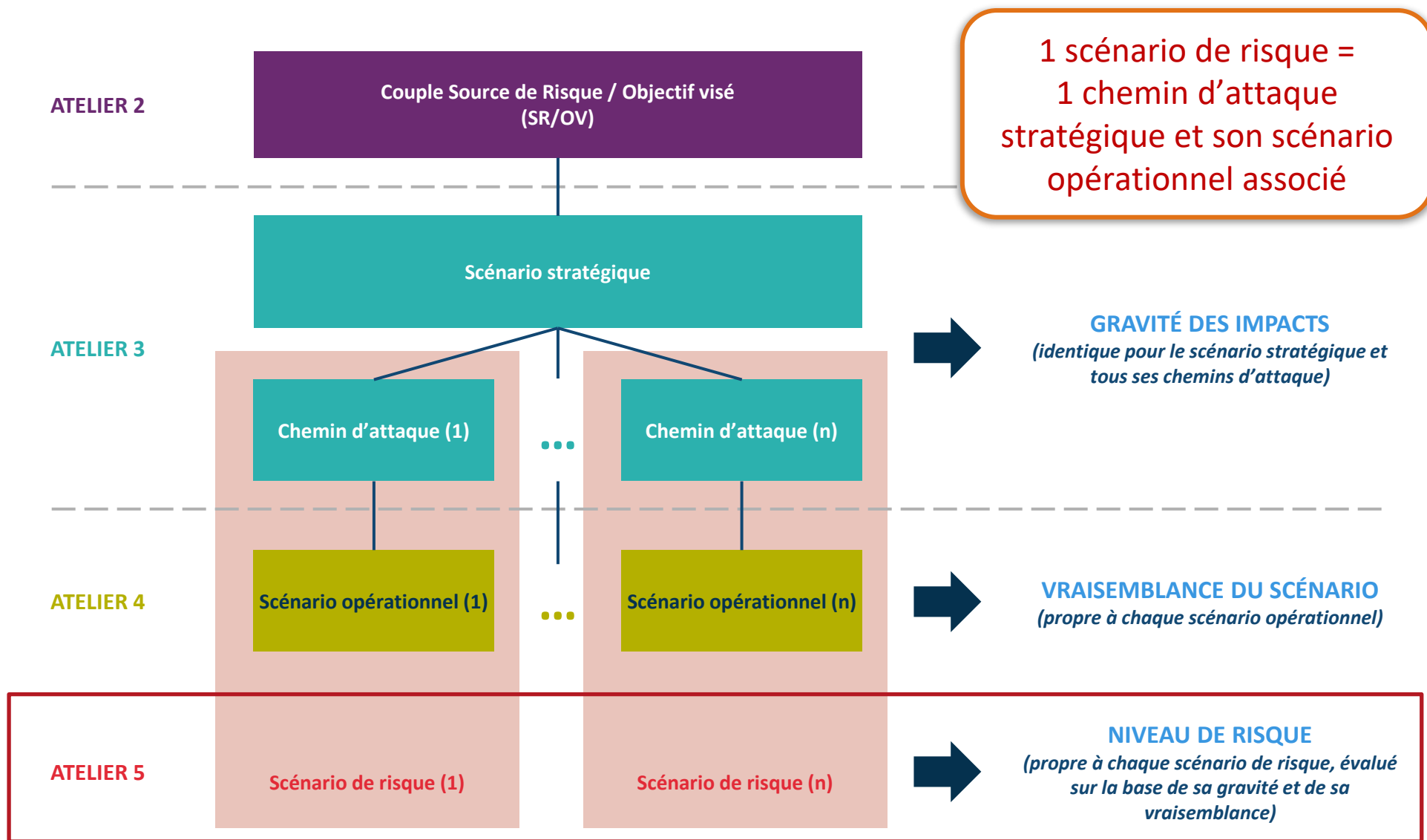
ÉLÉMENTS EN SORTIE :

- Stratégie de traitement du risque
- Plan d'amélioration continue de la sécurité (PACS)
- Synthèse des risques résiduels
- Cadre du suivi des risques



PARTICIPANTS : Direction, Métiers, RSSI, DSI

Rappel : articulation des ateliers



1. Décider de la stratégie de traitement du risque

Classes d'acceptation du risque

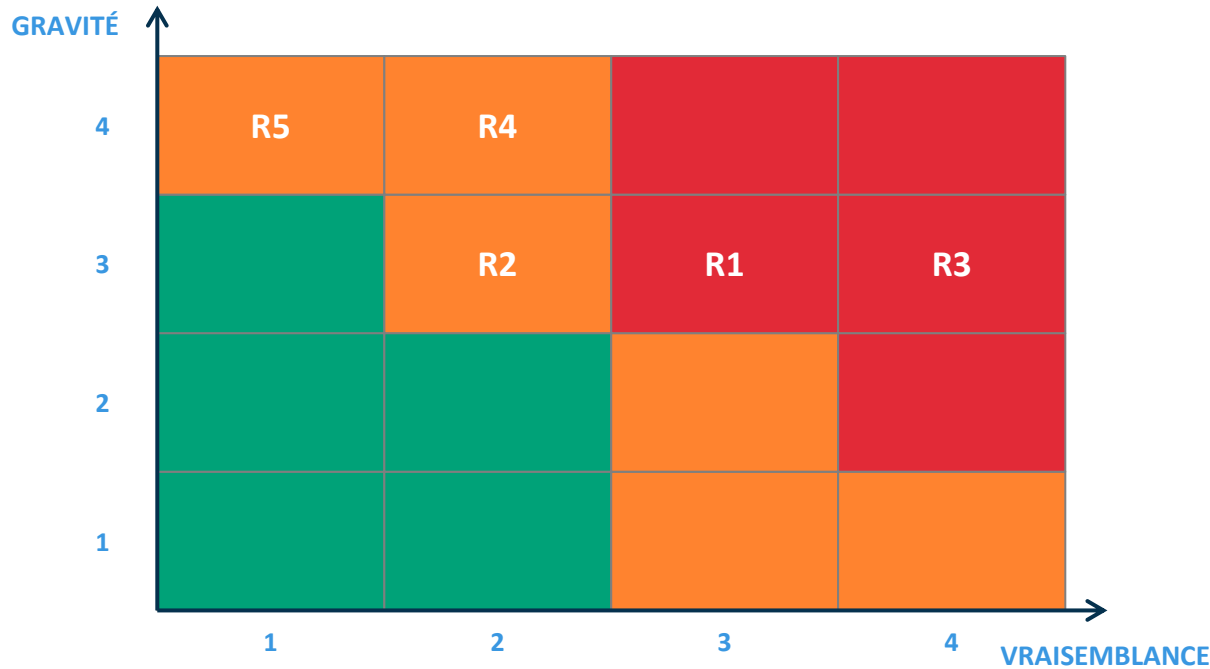
NIVEAU DE RISQUE	ACCEPTABILITÉ DU RISQUE	INTITULÉ DES DÉCISIONS ET DES ACTIONS
Faible	Acceptable en l'état	Aucune action n'est à entreprendre
Moyen	Tolérable sous contrôle	Un suivi en termes de gestion du risque est à mener et des actions sont à mettre en place dans le cadre d'une amélioration continue sur le moyen et long terme
Élevé	Inacceptable	Des mesures de réduction du risque doivent impérativement être prises à court terme. Dans le cas contraire, tout ou partie de l'activité sera refusé



1. Décider de la stratégie de traitement du risque

Représentation des risques et des seuils d'acceptation

Exemple : société de biotechnologie



- **R1** : Un concurrent vole des informations de R&D grâce à un canal d'exfiltration direct
- **R2** : Un concurrent vole des informations de R&D en exfiltrant celles détenues par le laboratoire
- **R3** : Un concurrent vole des informations de R&D grâce à un canal d'exfiltration via le prestataire informatique
- **R4** : Un hacktiviste provoque un arrêt de la production des vaccins en compromettant l'équipement de maintenance du fournisseur de matériel
- **R5** : Un hacktiviste perturbe la distribution de vaccins en modifiant leur étiquetage

La représentation de la stratégie de traitement doit permettre de comparer les risques les uns par rapport aux autres et être compréhensible par l'ensemble des participants

2. Définir les mesures de sécurité dans un PACS

Comment les identifier ?

COMMENT LES IDENTIFIER ?

Parcourez chaque scénario de risque et posez-vous la question suivante : *quelles sont les étapes ou actions élémentaires pour lesquelles il serait pertinent de renforcer la sécurité afin de rendre la tâche plus difficile pour l'attaquant, diminuer sa probabilité de réussite ?*

A3

A4

SUR QUOI PORTENT-ELLES ?

- Ecosystème
- Scénarios stratégiques
- Scénarios opérationnels

EN QUOI CONSISTENT-ELLES ?

- Renforcement du socle de sécurité
- Mesures *ad hoc* liées aux contextes d'emploi et de menace, en lien avec les scénarios stratégiques et opérationnels

2. Définir les mesures de sécurité dans un PACS

Comment les structurer ?

Protection

Se **prémunir** contre les attaques en rendant le SI et son écosystème les moins vulnérables et exposés possibles

Défense

Détecter les signaux faibles ou une attaque avérée et **réagir** pour en minimiser les impacts



Gouvernance

Anticiper la menace, suivre le niveau de sécurité et **renforcer** en continu le dispositif

Résilience

Assurer la **continuité** d'activité avec un niveau de dégradation tolérable, puis la **reprise** nominale progressive

2. Définir les mesures de sécurité dans un PACS

Comment les structurer ?

GOUVERNANCE ET ANTICIPATION	Gouvernance ♦ organisation de management du risque et d'amélioration continue; ♦ processus d'homologation; ♦ maîtrise de l'écosystème; ♦ gestion du facteur humain (sensibilisation, entraînement); ♦ indicateurs de pilotage de la performance numérique. Connaissance des vulnérabilités: ♦ audits de sécurité, veille. Connaissance de la menace: ♦ veille (renseignement, intelligence économique)
PROTECTION	♦ Cloisonnement des biens supports par domaines de confiance. ♦ Gestion de l'authentification et du contrôle d'accès. ♦ Gestion de l'administration/supervision. ♦ Gestion des entrées/sorties de données et des supports amovibles. ♦ Protection des données (intégrité, confidentialité, gestion des clés cryptographiques). ♦ Sécurité des passerelles d'interconnexion et des biens supports périmétriques (biens supports "de frontière"). ♦ Sécurité physique et organisationnelle. ♦ Maintien en condition de sécurité et gestion d'obsolescence. ♦ Sécurité des processus de développement, d'acquisition (chaîne d'approvisionnement) et de maintien en condition opérationnelle. ♦ Sécurité vis-à-vis des signaux parasites compromettants.
DÉFENSE	♦ Surveillance d'événements. ♦ Détection et classification d'incidents. ♦ Réponse à un incident cyber.
RÉSILIENCE	♦ Continuité d'activité (sauvegarde et restauration, gestion des modes dégradés). ♦ Reprise d'activité ♦ Gestion de crise cyber



2. Définir les mesures de sécurité dans un PACS

Exemple : société de biotechnologie

MESURE DE SÉCURITÉ	SCÉNARIOS DE RISQUES ASSOCIÉS	RESPONSABLE	FREINS ET DIFFICULTÉS DE MISE EN ŒUVRE	COÛT / COMPLEXITÉ	ECHÉANCE	STATUT
GOUVERNANCE						
Sensibilisation renforcée au hameçonnage par un prestataire spécialisé	R1	RSSI	Validation du CHSCT indispensable	+	6 mois	En cours
Audit de sécurité technique et organisationnel de l'ensemble du SI bureautique par un PASSI	R1, R5	RSSI		++	3 mois	À lancer
Intégration d'une clause de garantie d'un niveau de sécurité satisfaisant dans les contrats avec les prestataires et laboratoires	R2, R3, R4	Équipe juridique	Effectué au fil de l'eau à la renégociation des contrats	++	18 mois	En cours
Mise en place d'une procédure de signalement de tout incident de sécurité ayant lieu chez un prestataire ou un laboratoire	R2, R3, R4	RSSI / Équipe juridique		++	6 mois	À lancer
Audit de sécurité organisationnel des prestataires et laboratoires clés. Mise en place et suivi des plans d'action consécutifs	R2, R3, R4	RSSI	Acceptation de la démarche par les prestataires et laboratoires	++	6 mois	À lancer
Limitation des données transmises aux laboratoires au juste besoin	R2	Équipe R&D		+	3 mois	Terminé



2. Définir les mesures de sécurité dans un PACS

Exemple : société de biotechnologie

PROTECTION						
Protection renforcée des données de R&D sur le SI (pistes : chiffrement, cloisonnement)	R1, R3	DSI		+++	9 mois	En cours
Renforcement du contrôle d'accès physique au bureau R&D	R1	Équipe sûreté		++	3 mois	Terminé
Dotation de matériels de maintenance administrés par la DSI et qui seront mis à disposition du prestataire sur site	R4	DSI		++	9 mois	À lancer
Renforcement de la sécurité du système industriel selon les recommandations ANSSI	R4, R5	RSSI / DSI / Sûreté	Stratégie et plan d'action à définir et valider	+++	12 mois	À lancer
Chiffrement des échanges de données avec les laboratoires	R2	DSI	Identifier le produit de chiffrement et le faire accepter par les laboratoires	++	9 mois	À lancer
DÉFENSE						
Surveillance renforcée des flux entrants et sortants (sonde IDS). Analyse des journaux d'événements à l'aide d'un outil.	R1	DSI	Achat d'un outil, budget à provisionner	++	9 mois	À lancer
RÉSILIENCE						
Renforcement du plan de continuité d'activité	R4, R5	Équipe continuité d'activité		++	6 mois	En cours



2. Définir les mesures de sécurité dans un PACS

Sécurité en profondeur : un équilibre à atteindre

